

Lecture 1: Introduction to Information Security and the CIA Triad

What is Information Security?

Information security means **protecting information and information systems** from **unauthorized access, use, sharing, change, or destruction**.

It helps keep information **safe, correct, and available** when needed.

Goal:

To make sure information always stays **secure, reliable, and accessible** to the right people.

Example (Bangladesh):

In 2022, hackers attacked the **Bangladesh Election Commission** website and leaked voter information.

This shows how important it is to protect information.

Why Do We Learn Information Security?

We study information security to:

- **Protect personal data** such as NID, phone numbers, and bank details.
- **Keep organizations safe** from hackers and cyber threats.
- **Prevent cybercrimes** like fraud, ransomware, and hacking.
- **Build trust** among users of digital platforms and services.

Example:

Mobile banking apps like **bKash** and **Nagad** handle millions of transactions daily.

If they are not secure, people may **lose money** and **lose trust** in the service.

What is Security?

Definition:

Security means **achieving protection even when there are adversaries (attackers)** trying to harm or misuse the system.

Since the internet has many attackers, systems must be designed to **defend against them**.

A Good Security Plan Includes:

1. **Policy:** The goal or rule you want to follow.
 2. **Threat Model:** The possible actions an attacker might take.
 3. **Mechanism:** How the system will stop attacks and apply the policy.
 4. **Goal:** Make sure no attacker (within your model) can break your policy.
-

Why Is Security Hard?

- It is **easy to design a policy**, like “only authorized users can access the system.”
- But **hard to imagine every possible attack** that might happen in real life.
- Threat models are often **incomplete or unrealistic**, leaving room for new attacks.
- Even strong systems can fail if designers **did not consider all risks**.

That’s why security must be an **ongoing process** — we design, test, and update regularly. To truly understand security, we need to think like **both the attacker (Red Team)** and the **defender (Blue Team)**.

What Is Information Security?

It is the **practice and study of protecting information and information systems** from unauthorized access, use, or damage.

This includes everything from **data protection** to **system safety** and **user privacy**.

Information Security vs Cybersecurity

Aspect	Information Security	Cybersecurity
Focus	Protects all types of information (digital and physical).	Protects computer systems, networks, and digital data.
Example	Locking paper files in a safe cabinet.	Using firewalls, antivirus, and encryption to stop hackers.

Core Principles — The CIA Triad

The **CIA Triad** is the foundation of all information security systems.

It stands for **Confidentiality, Integrity, and Availability**.

These three together keep data safe and reliable.

1. **Confidentiality** – Protecting data from unauthorized access.
 2. **Integrity** – Ensuring data is correct and unmodified.
 3. **Availability** – Making sure data and systems are usable when needed.
-

I. Confidentiality – No Unauthorized Access

Confidentiality means **only authorized people** can view or use information. It prevents data from being leaked, exposed, or shared without permission.

Example:

When you log into your email, only **you** can read your messages — not anyone else.

Loss of Confidentiality:

Happens when information is **leaked** to someone who shouldn't see it, such as through hacking or accidental sharing.

II. Integrity – No Unauthorized Modifications

Integrity ensures that data stays **accurate, complete, and trustworthy**. No one can secretly modify or damage it.

Example:

When you submit an online job application, integrity ensures your information stays the same until it reaches the employer.

If someone changes your details in between, the system should detect and stop it.

Loss of Integrity:

Occurs when data is changed, deleted, or corrupted without permission.

III. Availability – Accessible to Authorized Users

Availability ensures that data and systems are **ready and working** whenever authorized users need them.

It also means preventing service interruptions or failures.

Example:

During a large sale, an e-commerce site must stay online and responsive.

If the site crashes, customers cannot complete purchases, and the business loses revenue.

Loss of Availability:

Occurs when systems are down due to attacks, power failure, or overload.

Example of CIA Triad: ATM Machine

- **Confidentiality:** Uses a card + PIN to verify the user.
 - **Integrity:** Keeps accurate records of all transactions.
 - **Availability:** ATMs are available for public use 24/7.
-

Tools for Achieving CIA Goals

Tools for Achieving Confidentiality

1. Encryption

Encryption hides information using mathematical algorithms so only authorized people can read it.

It is a key part of **cryptography**.

Types:

- **Symmetric Encryption:** Uses the same key to encrypt and decrypt data.
- **Asymmetric Encryption:** Uses two different keys – a public key and a private key.

Encryption ensures that even if data is stolen, attackers cannot understand it.

2. Access Control

Access control restricts access to sensitive information.

It defines **who can read, write, change, or delete data**.

Access Control Policies (ACP) explain:

- Who can access which resource.
- Under what conditions access is allowed.

These rules reduce data leaks and unauthorized access.

3. Authentication and Authorization

- **Authentication:** Confirms a user's identity (e.g., password, fingerprint, OTP).
- **Authorization:** Decides what that user is allowed to do (e.g., view only, edit data).

Example:

When you log into a railway booking website:

- The site checks your credentials (**authentication**).
- It then allows you to see your own tickets or cancel them but not access admin pages (**authorization**).

Both steps together maintain confidentiality.

Tools for Achieving Integrity

1. Data Backups

Keeping a copy of important data helps restore it if it is lost, deleted, or changed by mistake or attack.

Example:

If a hacker changes university marks, backups can recover the original records.

2. Checksum

A checksum is a small value calculated from data to detect errors during storage or transfer. If the received checksum doesn't match the original, the data was damaged.

Example:

Used in **TCP/IP networks** to ensure packets arrive correctly.

However, checksums can't prevent intentional tampering — only accidental damage.

3. Hashing

Hashing converts data into a **unique, fixed-length code** using mathematical functions such as **SHA-256** or **MD5**.

Properties:

- **One-way:** Cannot reverse a hash to get original data.
- **Fixed output:** Always produces the same length.
- **Unique:** Small changes in input produce very different hashes (avalanche effect).

Hashing is used for **password storage** and **digital signatures**.

4. Correction Codes

When data is transmitted as bits, errors can occur due to noise or interference.

Error-Correcting Codes (ECC) detect and fix these errors automatically.

Examples:

- **Hamming Code:** Detects 2-bit errors and fixes 1-bit errors.
 - **Reed–Solomon Code:** Used in CDs, DVDs, and QR codes to restore lost data.
-

Tools for Achieving Availability

1. Redundancy and Backup Systems

Redundancy means having **extra components or copies** of data so the system still works if one fails.

Example:

Cloud services store data in multiple locations.

If one server fails, others take over — users don't lose access.

2. Physical Protection

Physical security protects computers, servers, and networks from physical damage or power loss.

Common methods:

- Backup power (UPS, generators)
- Fire prevention systems
- Cooling and air conditioning
- Redundant hardware and disaster recovery sites

These ensure systems stay available even during emergencies.

Lecture 2: Principles of Information Security

Principles of Information Security

The main principles of information security help protect data and systems from attacks and misuse.

Each principle ensures information stays **confidential, correct, available, and trustworthy**.

Key Principles

1. **Confidentiality:**
Keeps information private. Only authorized users can access it.
Example: A student's marks should only be visible to teachers and the student.
2. **Integrity:**
Protects data from unauthorized changes, so it stays accurate and reliable.
Example: A hacker cannot change bank account balances without being detected.
3. **Availability:**
Ensures systems and information are available whenever users need them.
Example: An ATM should always work for customers 24/7.
4. **Authenticity:**
Confirms that data or a user is real and genuine, not fake.
Example: Verifying that a website is truly run by your bank before entering your password.
5. **Non-repudiation:**
Prevents people from denying their actions, like sending a message or signing a document.
Example: A person cannot deny making an online payment after confirmation.
6. **Accountability:**
Tracks user actions through logs and monitoring so each user is responsible for their behavior.
Example: Every admin's system changes are recorded in a log file.
7. **Privacy:**
Protects personal or sensitive data from misuse or exposure.
Example: A hospital must protect patient data from being shared publicly.
8. **Least Privilege:**
Gives users only the minimum access they need for their tasks.
Example: A clerk can view records but cannot delete or change them.
9. **Defense-in-Depth:**
Uses multiple layers of security to protect systems, like firewalls, passwords, and antivirus.
Example: Even if one layer fails, others still keep the system safe.

10. Risk Management:

Identifies and reduces potential risks to information and systems.

Example: Using encryption and strong passwords to reduce chances of data theft.

Non-Repudiation

Repudiation means denying that you performed an action, such as sending an email or changing data.

In security, this causes problems because we need to prove who did what.

Non-repudiation ensures that:

- The **sender cannot deny sending** a message.
- The **receiver cannot deny receiving** a message.

This provides **proof of action** for both sides.

Example:

- A handwritten signature proves a person agreed to something.
- A digital signature ensures the sender cannot deny sending a file or email.

To achieve non-repudiation, systems use:

- **Digital signatures**
- **Encryption**
- **Audit logs**
- **Time stamps**

These create a verifiable record of every action.

Digital Signatures for Non-Repudiation

Digital signatures ensure messages or documents are genuine and untampered with.

How They Work:

1. A **hash function** creates a unique digital code (called a message digest) from a document.
2. This hash is **encrypted with the sender's private key** — creating a **digital signature**.
3. The receiver uses the **sender's public key** to **decrypt and verify** the signature.

If the document is changed after signing, the hash value changes, showing **tampering** immediately.

Benefits:

- Confirms the sender's identity.
 - Ensures the document has not been changed.
 - Provides legal and technical proof that the sender cannot deny sending it.
-

Authenticity

Authenticity checks whether something (a person, message, or system) is **genuine and trustworthy**.

It helps prevent **fraud and fake identities**.

Definition:

Authenticity ensures information and communication come from a **real and verified source**.

Why It's Important:

- Prevents unauthorized access.
- Builds trust between users and systems.
- Protects against fake or copied data.

Example:

When you buy something online, the **https://** and lock symbol in the browser show the website is authentic.

It means your data is encrypted and the site is genuine, not a fake one.

Principles of Authenticity

Authenticity in cybersecurity helps maintain **trust and confidence** in communication.

It includes the following principles:

1. **Origin of Data:**
Make sure the information truly comes from its claimed source.
2. **Genuineness and Verifiability:**
The message or data must be original and verifiable, not copied or forged.
3. **Confidence in Validity:**
The receiver should feel confident that the data is real and unaltered.

4. **Multi-Factor Authentication (MFA):**

Use more than one method (like password + OTP + fingerprint) to verify a user's identity.

Together, these help confirm that both the sender and the message are real and safe.

Ensuring Authenticity in Digital Communications

To maintain authenticity in online communications, we use multiple security methods and technologies.

Key Techniques:

1. **Multi-Factor Authentication (MFA):**

Uses several ways to confirm identity, such as password, biometric (fingerprint/face), and OTP code.

2. **Hashing and MAC:**

- **Hashing:** Creates a digital fingerprint of data.
- **MAC (Message Authentication Code):** Ensures the message is unchanged and from a trusted source.
- **HMAC:** A stronger form of MAC that adds encryption.

3. **Asymmetric Cryptography:**

Uses a public and private key pair for secure communication.

Example: Used in digital certificates and emails for secure exchange.

4. **Secure Protocols:**

Uses technologies like **SSL**, **TLS**, and **HTTPS** to encrypt data between user and website.

Example: Online banking websites use HTTPS to protect transactions.

Accountability

Accountability means **tracking actions** and holding users responsible for what they do on a system.

- It ensures that **authenticated users** follow the rules and ethics of the organization.
- It helps **detect and punish wrongdoing** by monitoring user activities.
- Logs and reports are used as evidence in case of misuse.

Example:

If a user knows that their actions are being recorded, they will think twice before breaking rules or leaking data.

Tools Used:

- System activity logs
- Security audits
- User tracking software

Accountability builds a **safe, responsible environment** inside an organization.

Privacy

Privacy means **protecting personal information** and respecting a person's right to control how their data is used.

Example:

When guests visit your home, they can use common areas but not see your bank documents or ID cards.

Similarly, in digital systems, some data must stay private and hidden from others.

Security vs Privacy

Aspect	Privacy	Security
Focus	Controls who can access or use personal data.	Protects data from unauthorized access, loss, or tampering.
Goal	Ensure data is shared only with authorized people.	Ensure data remains confidential, accurate, and available.
Example	Only you and your bank can see your account details.	Encryption and strong passwords protect that account.

Together, privacy and security protect users from data misuse and cyber threats.

Least Privilege

Least privilege means **giving users only the access they need**, nothing more. This reduces the chances of mistakes, misuse, and cyberattacks.

Example:

- A database user who only needs to **view** a table should not have permission to **edit or delete** it.
- A worker should not install software that requires admin rights if it's not part of their job.

This principle **reduces the attack surface** and **stops malware** from spreading widely.

Defense-in-Depth

Definition:

Using **multiple layers of protection** so that if one fails, others still keep the system safe.

Example:

Banks use multiple layers of defense:

- Security guards
- Cameras and alarms
- Vaults and locks

In digital systems, layers may include:

- Firewalls
- Multi-factor authentication
- Encryption
- Biometric verification
- Access control

This multi-layer approach ensures attackers cannot easily reach critical data.

Risk Management

Definition:

Risk management is the process of **identifying, analyzing, and reducing potential risks** to data and systems.

Steps in Risk Management:

1. **Identifying Risks:**
Recognize possible threats like hacking, phishing, or data breaches.
2. **Assessing Risks:**
Evaluate how serious each threat is and what damage it could cause.

3. **Mitigating Risks:**

Take steps to reduce the impact — such as encryption, regular updates, backups, and strong passwords.

Example:

A company may find that weak passwords could lead to a data breach.

To reduce this risk, it enforces password rules, uses MFA, and monitors logins.

Thank You

Lecture 3: Types of Attacks

‘Attack’ in Cyber and Information Security

An **attack** is a deliberate action by an attacker (or hacker) to harm or misuse a computer system or network.

It aims to **break the confidentiality, integrity, or availability** of information.

In simple terms, an attack tries to:

- Steal information
- Gain unauthorized access
- Disrupt or damage systems

Formula:

Attack = Motive (Goal) + Vulnerability + Method

- **Motive:** Why the attacker wants to attack (e.g., money, revenge, or fame).
 - **Vulnerability:** The weakness or loophole in the system.
 - **Method:** The way or technique used to perform the attack.
-

Types of Attacks

There are two major categories of attacks:

1. **Passive Attacks** – Attackers observe or collect data without changing anything.
2. **Active Attacks** – Attackers actively modify or damage data or systems.

Passive Attack

A **passive attack** is when an attacker secretly monitors or listens to data transmission. The attacker does not modify or delete data; they just collect information.

Goal: To **gain information** without being detected.

Common Examples: Eavesdropping, traffic analysis.

Types of Passive Attacks

1. **Release of Message Content**
2. **Traffic Analysis**

Passive Attack (Release of Message Content)

In this attack, the attacker secretly listens to a conversation or communication not meant for them.

Example:

- Listening to a phone call
- Reading someone's emails
- Capturing transferred files

The attacker may use this information for:

- Spying
- Blackmail
- Stealing secrets or private information

This type of attack **violates confidentiality**.

Passive Attack (Traffic Analysis)

Traffic analysis means the attacker watches **how and when information is exchanged**, even if the content is encrypted.

By studying the communication pattern, the attacker can find:

- Who is communicating with whom
- The frequency and timing of messages
- The size or amount of data sent
- The possible location of users

Even without reading the actual message, this gives attackers **useful intelligence** about systems or networks.

Active Attack

An **active attack** directly interferes with the communication or system. The attacker **modifies, deletes, or inserts** data to cause damage or gain control.

Goal: To change data, disrupt service, or gain access.

Common Types of Active Attacks

1. **Masquerade**
 2. **Modification of Messages**
 3. **Replay**
 4. **Denial of Service (DoS)**
-

Active Attack (Masquerade)

A **masquerade attack** happens when an attacker pretends to be a **trusted user or system** to gain access.

Example:

A hacker logs in using stolen credentials and acts like the real user.

How Masquerade Attacks Work:

- Using stolen usernames or passwords
- Creating fake identities or devices
- Using malicious software to trick authentication systems

Results:

- Data theft
- Financial loss
- System misuse

Forms of Masquerade Attacks

1. **User Masquerade:**
The attacker steals a user's credentials (like username and password) through phishing or password cracking and logs in as that user.
 2. **Device Masquerade:**
The attacker pretends to be a trusted device on the network by copying its MAC or IP address to bypass network security.
 3. **Website Masquerade:**
The attacker builds a fake website similar to a real one to trick users into entering their personal or payment information.
Example: Fake bank websites that look real.
 4. **Application Masquerade:**
The attacker creates a fake app that looks legitimate but secretly steals data or installs malware after users download it.
 5. **System Masquerade:**
The attacker disguises their own system or network as a trusted one to intercept communication or reroute network traffic.
-

Active Attack (Modification of Message)

In this attack, the attacker changes the content of a message during transmission. They may also delay, reorder, or resend messages to cause confusion.

Example:

A message saying "Allow Alice to read confidential file" is changed to "Allow Bob to read confidential file."

This attack **violates data integrity** and can lead to:

- Unauthorized access
 - False information being accepted as true
 - Serious system damage
-

Active Attack (Replay)

A **replay attack** happens when an attacker captures a valid message and later resends it to perform an unauthorized action.

Example:

If a message “Transfer 1000 Taka” is sent, the attacker saves it and sends it again later — causing the bank to make another transaction.

Where Replay Attacks Happen:

- Online banking
- E-commerce
- Smart cars (keyless entry systems)

Attackers use this to **repeat valid actions** like payments or logins without permission.

Goal:

Reuse previously captured data to gain access or perform actions again.

Active Attack (Denial of Service - DoS)

A **Denial of Service (DoS)** attack tries to make a computer, website, or network unavailable to users.

How It Works:

The attacker floods the system with too many fake requests or data so that real users cannot access it.

Example:

If a bank’s website can only handle 10 users per second, the attacker sends 100 fake requests every second.
This makes the site crash, blocking real customers.

Effects:

- Website or service becomes unavailable
 - Loss of revenue
 - Damaged reputation
-

Insider Attack

An **insider attack** is performed by someone **within the organization** — like an employee, contractor, or manager — who already has authorized access.

Examples:

- Stealing company data
- Selling confidential information
- Intentionally damaging systems

Why It's Dangerous:

Insiders already have passwords or access rights, so their attacks are harder to detect.

External Attacks

External attacks come from **outside the organization** — by hackers, cybercriminals, or competitor groups.

They target networks, websites, or databases to gain access or cause harm.

Examples:

- Hacking a company's website
- Sending malware or phishing emails
- Distributed Denial of Service (DDoS) attacks

External attackers don't have authorized access, so they must break through security barriers.

Network-Based Attacks

These attacks target **network infrastructure and communication systems**.

Goal:

To intercept, steal, or disrupt network data.

Examples:

- Packet sniffing (capturing network traffic)
- Man-in-the-middle attacks (intercepting communication)
- IP spoofing or session hijacking
- Denial of service (flooding the network)

Network-based attacks aim to **break confidentiality, integrity, or availability** of communication.

Host-Based Attacks

Host-based attacks target individual computers, servers, or software. The goal is to take control of the system or steal data stored on it.

Common Types of Host-Based Attacks:

1. **Virus**
 2. **Worm**
 3. **Trojan Horse**
 4. **Back Door**
 5. **Trap Door**
-

1. Virus

A **virus** is malicious software that attaches itself to other programs or files and spreads when those files are used.

Symptoms:

- System freezes or crashes
 - Slow performance
 - Strange pop-ups or file corruption
-

2. Worm

A **worm** is similar to a virus but spreads automatically without human help. It uses network connections to copy itself to other computers.

Symptoms:

- Sudden restarts
 - Unusual error messages
 - Programs stop working properly
 - Heavy network traffic
-

3. Trojan Horse

A **Trojan Horse** looks like a legitimate program but secretly performs harmful actions. It tricks users into installing it.

Example: A fake antivirus app that steals data instead of protecting the system.

Symptoms:

- Mouse or keyboard acts on its own
 - Volume increases or decreases automatically
 - Sensitive files disappear or get sent online
-

4. Back Door

A **back door** is a hidden way to access a system that bypasses normal security. Hackers use it to enter systems again after an initial attack.

Example:

After infecting a system with malware, the attacker leaves a secret entry point for future use.

5. Trap Door

A **trap door** (or logic bomb) is code hidden inside a program that triggers under specific conditions.

When activated, it performs malicious actions such as deleting files or changing passwords.

Example:

A programmer inserts a trap door that erases all company data if they get fired.

Thank You

Lecture 4: Information Warfare

What is Information Warfare

Information Warfare (IW) refers to the **use of information and communication technology (ICT)** to gain a **strategic advantage** in military, political, or economic conflicts.

It involves **manipulating, attacking, or defending** information systems to achieve goals.

In simple terms, it is the battle to **control, protect, or destroy information**.

Main Purpose:

To use information as a weapon — to influence, deceive, disrupt, or defend.

Example:

A country may spread fake news online or hack another nation's communication systems to gain an advantage during conflict.

Information Warfare Strategy

Information warfare can be carried out using two main strategies:

1. **Defensive Information Warfare**
 2. **Offensive Information Warfare**
-

Defensive Information Warfare

Definition:

Defensive information warfare focuses on **protecting one's own data, networks, and systems** from attacks.

The main goal is to maintain the **Confidentiality, Integrity, and Availability (CIA)** of information and systems.

Objectives:

- Prevent unauthorized access
 - Reduce data breaches
 - Respond quickly to cyber incidents
 - Protect organizational reputation
-

Defensive Information Warfare Tactics

1. **Cybersecurity Practices**
2. **Incident Response**
3. **Encryption**
4. **Access Control**
5. **Security Awareness Training**
6. **Vulnerability Management**
7. **Security Monitoring and Analytics**

Each of these tactics plays a role in defending digital systems from cyber threats.

Cybersecurity Practices

- Use **firewalls, antivirus, and intrusion detection systems** to block attacks.
 - Regularly **update and patch** software to fix vulnerabilities.
 - Apply **strong passwords and authentication systems**.
 - Limit access to only authorized users.
- These steps form the first line of defense against hackers.
-

Incident Response

- Prepare an **incident response plan** to act quickly after an attack.
 - Detect, isolate, and remove threats as soon as possible.
 - Analyze what went wrong and update systems to prevent future attacks.
 - Example: If a data breach occurs, immediately disable affected accounts and inform users.
-

Encryption

Encryption turns readable data into coded form so unauthorized people can't read it. Even if hackers steal data, they can't understand it without the key.

Example:

Banking apps use encryption to protect your transaction details during online transfers.

Access Control

Access control ensures only **authorized users** can view or change information. It uses techniques like **passwords, biometrics, and role-based access**.

Principles used:

- **Least Privilege:** Give users the minimum access needed.
 - **Multi-Factor Authentication (MFA):** Add extra layers of login security.
-

Security Awareness Training

Humans are often the weakest link in security.

Training helps users:

- Recognize phishing emails or scams
- Use strong passwords
- Avoid unsafe downloads and websites
- Report suspicious activity early

Well-trained employees reduce the chances of successful attacks.

Vulnerability Management

- Regularly scan systems for weaknesses (vulnerabilities).
 - Patch and update software to fix those weaknesses.
 - Remove or disable unused programs and services that could be exploited.
This helps reduce possible attack entry points.
-

Security Monitoring and Analytics

Constantly observe systems for unusual activities or cyber threats.

Use **security analytics tools** and **intrusion detection systems (IDS)** to:

- Detect suspicious patterns
- Analyze logs
- Alert administrators to take action quickly

This ensures early warning before major damage occurs.

Offensive Information Warfare

Definition:

Offensive information warfare involves **attacking or exploiting an enemy's information systems** to gain an advantage.

The goal is to **disrupt operations, steal data, or spread misinformation**.

While defensive warfare focuses on protection, offensive warfare focuses on **attack and manipulation**.

Objectives of Offensive Information Warfare

- Gather intelligence about the enemy
 - Disrupt communication and operations
 - Steal or destroy data
 - Influence public opinion through false information
 - Create confusion and mistrust
-

Common Offensive Information Warfare Tactics

1. **Cyber Espionage**
 2. **Cyber Attacks**
 3. **Denial of Service (DoS) Attack**
 4. **Advanced Persistent Threats (APTs)**
 5. **Disinformation and Propaganda**
 6. **Data Manipulation**
 7. **Hardware Tampering**
-

Cyber Espionage

Cyber espionage means **spying through digital networks** to steal sensitive or classified data. Attackers secretly enter an organization's system to gather valuable information.

Targets:

- Military databases
- Government files
- Company secrets or research data

Example:

Hacking another nation's defense system to gather intelligence about its operations.

Cyber Attacks

Cyber attacks are deliberate attempts to **damage, disable, or steal** information from another system or organization.

Examples:

- Hacking into communication systems
- Destroying databases
- Shutting down critical infrastructure like power grids

Cyber attacks can disrupt the economy or national security.

Denial of Service (DoS) Attacks

In a **DoS attack**, attackers flood a system or website with fake requests so real users cannot access it.

It causes the system to **crash or slow down**.

Use in Warfare:

- Disable enemy communication systems
- Prevent access to government or military websites
- Interrupt online services

Example:

During political conflicts, attackers may bring down government portals to block public access.

Advanced Persistent Threats (APTs)

An **APT** is a **long-term, stealthy cyber campaign** where attackers secretly enter a network and stay hidden for months or years.

Their goal is to continuously steal data or monitor activities.

Characteristics:

- Well-funded and highly skilled attackers
- Use multiple attack methods
- Hard to detect and remove

Example:

Nation-state hackers using APTs to spy on foreign governments or steal business data.

Disinformation and Propaganda

Disinformation:

Spreading **false or misleading information** online to confuse or manipulate people.

Propaganda:

Using information (true or false) to **influence people's beliefs or emotions**.

Example:

- Fake social media posts during elections to mislead voters.
- Spreading lies to damage a country's image.
- Publishing manipulated news to create panic or distrust.

Propaganda can expose embarrassing truths or spread lies to weaken morale.

Data Manipulation

Attackers may **alter or delete critical data** in an enemy's systems to create chaos or wrong decisions.

Examples:

- Changing military communication orders.
- Modifying stock market or bank data.
- Corrupting research or scientific databases.

Data manipulation can cause serious confusion and loss of trust.

Hardware Tampering

Hardware tampering happens when attackers **modify physical computer components** during production or shipment.

They install secret chips or tools that help them spy on users or collect information later.

Example:

Embedding hidden spying chips inside devices or servers to monitor another country's digital systems.

This is a dangerous long-term threat because it is hard to detect.

Information Warfare - Russia Ukraine

The Russia–Ukraine conflict is a real-world example of information warfare. Both countries use cyber attacks and online propaganda to influence people and disrupt systems.

Examples:

- Hacking of government and military websites.
- Spreading fake news on social media to control public opinion.
- Launching DoS attacks on banks and communication networks.
- Using digital spying tools to steal or block military data.

This shows how **modern wars** are not only fought with weapons but also through **cyber and information attacks**.

Thank You

Lecture 5: Threats to Security

Threats to Personal Security

Threats to personal security are **risks and dangers** that can harm a person's privacy, data, or safety in the digital world.

They can cause loss of personal information, identity theft, or financial damage.

Common Threats:

1. Social Engineering
 2. Malware
 3. Identity Theft
 4. Password Attacks
 5. Public Wi-Fi Risks
 6. Lack of Software Updates
 7. Fake Apps and Software
 8. Scams
 9. Physical Theft of Devices
-

1. Social Engineering

Social engineering means **tricking people into revealing confidential information** or doing actions that reduce security.

Instead of hacking computers, attackers **manipulate human psychology** to get what they want.

Example:

An attacker pretends to be a bank officer and asks you for your PIN or OTP.

Social Engineering Attacks

Common types of social engineering include:

1. **Phishing:**
Fake emails or messages that look real and ask you to share personal information or click on a link.
 2. **Spoofing:**
Creating fake websites or emails that appear to come from a trusted source.
 3. **Whaling:**
Targeted phishing attack aimed at high-level people like executives or managers.
 4. **Baiting:**
Offering something attractive (like free music or software) to make victims install malware or reveal information.
-

Preventive Measures of Social Engineering Risks

- Be careful when sharing personal details online or in person.
 - Always verify who is asking for sensitive data.
 - Be suspicious of unexpected emails or calls requesting information.
 - Learn about common scams and train others.
 - Use **strong passwords** and **multi-factor authentication (MFA)**.
 - Avoid oversharing personal information on social media.
-

Phishing

Phishing is one of the most common forms of social engineering.

Attackers send fake emails, messages, or links pretending to be real organizations.

The goal is to steal:

- Login credentials
- Credit card details
- Personal data

Example:

Fake URLs like:

- <https://faccbook.com/>
- <https://facebo0k.com/>
- <https://mail.googlec.com/>

These look real but lead to fake websites that collect your data.

Example: Gmail Phishing

Attackers send emails pretending to be from Gmail, asking users to log in or verify accounts. When users click the fake link and enter credentials, attackers steal their login details.

Phishing – Attack Impact Example

Think of a phishing campaign like a funnel:

- A hacker sends **1,000,000 fake emails**.
- Only **0.5% (5,000 people)** click on the link.
- **20% of them (1,000 people)** enter their login info.
- If each victim loses **\$10**, the hacker makes **\$10,000 profit**.

This shows how small success rates can still lead to large profits.

Preventive Measures of Phishing Attacks

- Learn how phishing scams work.
- Be cautious with unexpected emails or messages.
- Always check the sender's email address carefully.
- Hover over links before clicking to see the real URL.
- Use **MFA (Multi-Factor Authentication)**.
- Install **trusted antivirus software**.
- Be careful with what you share on social media.
- Report any suspected phishing to authorities or IT support.

2. Malware

Malware means **malicious software**.

It includes programs created to **damage, steal, or control** computer systems.

Common Types:

- **Viruses**
- **Worms**
- **Trojan Horses**
- **Spyware**
- **Ransomware**
- **Adware**

Purpose: To harm systems, steal data, or spy on users.

How Malware Spreads:

- Infected downloads
- USB or removable drives
- Email attachments
- File-sharing or torrent sites
- Cracked or fake software

Preventive Measures of Malware Attack

- Install and regularly update **antivirus software**.
- Keep all software and operating systems up to date.
- Don't open attachments or links from unknown senders.
- Download apps only from **official stores** (like Play Store or App Store).
- Use **strong network passwords** and encryption.
- Regularly **back up your data**.
- Use unique, complex passwords for all accounts.
- Learn how to recognize social engineering tricks.

3. Identity Theft

Identity theft occurs when someone **steals your personal information** and uses it for fraud or crime.

Stolen Data Can Include:

- Name and address
- Date of birth
- National ID or social security number
- Bank account or card details

Attackers Use It To:

- Open fake bank accounts
 - Apply for loans
 - Make online purchases
 - Commit crimes under your name
-

Preventive Measures of Identity Theft

- Keep personal documents and digital data secure.
 - Use **strong passwords** and **multi-factor authentication**.
 - Avoid sharing sensitive information with strangers or unverified sites.
 - Don't use public Wi-Fi for banking or shopping.
 - Regularly check bank and credit reports for unusual activity.
 - Shred documents containing personal data.
 - Share minimal information online.
 - Consider freezing your credit if not in use.
-

4. Password Attacks

Attackers try to guess or steal passwords to gain system access. They often use automated tools and databases of stolen passwords.

Common Types:

- **Brute Force Attack**
- **Dictionary Attack**

Examples of Weak Passwords:

- 12345
- Password
- YourName123
- YourBirthday

- PetName
- StudentIDNumber
- Religious words (like “Allah123”)

Weak passwords are easy to guess or crack.

Brute Force Attack

In a brute force attack, the hacker tries **every possible combination** of letters, numbers, and symbols until the correct password is found.

Example:

Trying 123456, then 123457, then 123458, and so on.

Attackers often use software to speed up this process.

Limitation:

It takes time, especially if the password is long and complex.

Dictionary Attack

A **dictionary attack** is similar to brute force but uses **lists of common words and passwords**. Attackers guess passwords from these lists, often using:

- Names of pets or people
- Movie characters
- Common patterns like “qwerty123” or “abc123”

They also mix words with numbers or symbols, e.g., “passw0rd!” or “admin@123”.

Preventive Measures of Password Attacks

- Use **strong passwords** (at least 12 characters, mix of letters, numbers, and symbols).
 - Avoid using personal details like name or birthday.
 - Don’t use common sequences (like 12345 or abcdef).
 - Change passwords regularly.
 - Use a **password manager** to store and generate secure passwords.
-

5. Public Wi-Fi Risks

Public Wi-Fi in cafes, airports, or malls is often **unsecured**, making it easy for hackers to intercept your data.

Main Threat:

Man-in-the-Middle (MITM) Attack –

A hacker secretly intercepts or changes communication between you and a website or app.

Result:

Hackers can steal login details, banking data, or personal messages.

Preventive Measures of Public Wi-Fi Risks

- Always use websites that show “**https://**” (secure connection).
 - Avoid entering passwords or banking info on public networks.
 - Use a **VPN (Virtual Private Network)** to encrypt your internet connection.
 - Verify the real Wi-Fi network name before connecting.
 - Be alert for unusual pop-ups or redirects.
-

6. Lack of Software Updates

Not updating software leaves devices open to **known vulnerabilities** that attackers can easily exploit.

Software Update (Patch):

A small fix or upgrade that removes bugs, adds features, or strengthens security.

Example:

When your phone or laptop asks for a system update, ignoring it increases the chance of being hacked.

Tip:

Enable **automatic updates** so your system stays secure.

7. Fake Apps and Software

Fake apps look like real ones but are created to steal data or install malware. They usually copy names and icons of popular apps.

Example:

A fake version of WhatsApp or a free antivirus app that secretly steals your contacts or photos.

Risks:

- Data theft
 - Unauthorized payments
 - Device damage
-

Preventive Measures of Fake Apps and Software

- Keep your device and apps updated.
 - Download apps **only from trusted sources** (Play Store, App Store).
 - Read app reviews before downloading.
 - Avoid sharing personal or financial details on unknown apps.
 - Be cautious of free offers or deals that seem “too good to be true.”
 - If unsure, don’t install or respond.
-

8. Scams

A **scam** is a **fraudulent trick** used to make victims share personal information or money. Scammers often rely on trust or emotion to deceive people.

Examples:

- Fake online stores offering discounts.
- Lottery or prize scams.
- Fake charity donation requests.
- Investment or job offer scams.

Goal:

To steal personal details, bank info, or payment data.

Common Types of Scams

- **Email scams:** Asking for urgent payment or donations.

- **Online shopping scams:** Selling fake or nonexistent products.
 - **Tech support scams:** Pretending to be from Microsoft or Apple to “fix” your computer.
 - **Romance scams:** Using fake identities to build trust and ask for money.
-

9. Physical Theft of Devices

This happens when your phone, laptop, or USB drive is stolen to access the data inside.

Risks:

- Exposure of personal or business information
- Financial loss
- Unauthorized account access

Preventive Measures:

- Always **lock devices** with passwords, PINs, or biometrics.
 - Enable **device tracking** (e.g., Find My Device, Find My iPhone).
 - Encrypt sensitive files.
 - Don’t leave devices unattended in public.
 - Report stolen devices to the police and block accounts if possible.
-

Thank You

Lecture 6: Malware

What is Malware?

Malware stands for **malicious software**.

It refers to any software created to **harm, exploit, or control** computer systems, devices, or data **without the user’s consent**.

Malware includes programs like **viruses, worms, Trojans, spyware, adware, ransomware**, and more.

Its main goals are to:

- Infiltrate systems
- Steal data
- Damage files
- Slow performance
- Spread to other computers

Example:

The first malware was the “**Creeper**” virus, created by **Bob Thomas** in the early 1970s. It was not harmful — it was an experiment — but it became the foundation of modern malware.

Why Malware Is Created

Malware programmers create and use malware to:

- Attack browsers and track visited websites
 - Slow down or crash systems
 - Cause hardware failure
 - Steal personal data such as contacts or passwords
 - Erase important files and cause data loss
 - Spread to other systems from an infected one
 - Send spam or advertising emails automatically
-

Example of a Simple Malware Code

```
@echo off
:A
Start Notepad
goto A
```

Explanation:

This small batch program repeatedly opens Notepad until the system restarts. It's a simple example of how malware can behave.

Different Ways Malware Can Enter a Network

- Downloading infected files or attachments
- Plugging in infected USB drives
- Visiting malicious websites
- Installing fake or pirated software
- Clicking phishing links

- Opening spam emails
-

Types of Malware

1. Viruses

- A **virus** is a program that attaches itself to files or system areas.
 - When the file runs, the virus **replicates** and spreads to other files.
 - Viruses can **corrupt data**, delete files, or slow down systems.
 - Some may be harmless, but most cause damage.
 - They spread through:
 - Email attachments
 - Infected downloads
 - USB drives
 - Network vulnerabilities
-

2. Worms

- Worms are similar to viruses but can **spread automatically** without user action.
 - They move through networks and infect connected systems.
 - If one computer in an office is infected, the worm can spread to others quickly.
 - Worms **consume bandwidth**, slow networks, and can damage systems.
-

3. Trojans (Trojan Horses)

- A **Trojan** looks like a normal or useful program but secretly performs harmful actions.
 - It may steal data, install malware, or open a backdoor for hackers.
 - The name comes from the **ancient Greek Trojan Horse** story — a hidden threat inside something that looks safe.
 - Example: A fake game installer that secretly steals passwords.
-

4. Adware

- **Adware** shows unwanted advertisements to users.
- It may track browsing habits to display targeted ads.

- Though less dangerous, it can slow systems and invade privacy.
-

5. Ransomware

- **Ransomware** locks or encrypts a victim's files and demands money to unlock them.
 - Even if victims pay, there's no guarantee the files will be restored.
 - It can cause huge financial loss and downtime.
-

6. Spyware

- **Spyware** secretly collects information from the infected device.
 - It can steal:
 - Passwords
 - Credit card details
 - Browsing habits
 - It operates silently in the background.
-

7. Keyloggers

- **Keyloggers** record all the keys you press on your keyboard.
- Attackers use them to capture:
 - Login credentials
 - Bank details
 - Messages

Types:

- **Software-based:** Installed as malware programs.
 - **Hardware-based:** Small devices attached to keyboards or ports.
-

8. Botnets

- A **botnet** is a network of infected computers (called "bots") controlled by a hacker.
- Attackers use botnets to:
 - Launch **DDoS attacks**
 - Send spam
 - Steal data
- Botnets grow by infecting many vulnerable devices.

9. Rootkits

- **Rootkits** hide malware from antivirus and system administrators.
 - They give attackers **deep access** to the operating system.
 - They are **difficult to detect or remove** once installed.
-

10. Fileless Malware

- Works directly from **system memory** instead of saving files on disk.
 - Hard to detect since it leaves **no trace** on the drive.
 - Often uses legitimate system tools (like PowerShell) to perform attacks.
-

11. Mobile Malware

- Targets **smartphones and tablets**.
- Examples include:
 - Fake apps
 - Mobile ransomware
 - Spyware that reads messages or contacts

Mobile malware can steal data or track user activity.

12. Remote Access Trojans (RATs)

- RATs give hackers **remote control** over an infected device.
 - They can:
 - Steal data
 - Watch through the webcam
 - Monitor screens or keystrokes
 - Often used for spying and unauthorized access.
-

Malware Components

Malware usually has several key parts working together.

1. Loader

- Starts the execution of malware.
- Loads malicious code into memory to begin infection.

2. Payload

- The main part that performs the malicious activity.
- Can:
 - Steal information
 - Damage systems
 - Spread infection
- Often encrypted or hidden to avoid detection.

3. Command and Control (C2) Communication

- Malware connects to a remote **C2 server** to:
 - Receive new commands
 - Send stolen data
 - Download updates
 - Allows attackers to control infected systems remotely.
-

4. Persistence Mechanism

- Ensures malware stays active even after restart.
 - Achieved by:
 - Modifying Windows Registry
 - Adding startup files
 - Creating hidden system tasks
-

5. Evasion Techniques

- Used to hide malware from antivirus or detection tools.
 - Common methods:
 - **Polymorphism:** Changing its appearance each time it spreads
 - **Rootkit functionality:** Hiding files and processes
 - **Anti-analysis:** Detecting if it's being analyzed in a lab environment
-

6. Data Exfiltration Module

- If malware's goal is to **steal data**, this component:
 - Collects files
 - Compresses and encrypts them
 - Sends them to a remote attacker
-

Malware Analysis

Malware analysis means studying malware to understand what it does, how it spreads, and how to remove it.

It helps cybersecurity experts identify, defend, and prevent future attacks.

There are two main types:

1. Static Analysis

- Analyzing malware **without running it**.
 - Experts check:
 - Code
 - Strings
 - File structure
 - Hashes
 - Memory dumps
 - Purpose: Understand what the malware is supposed to do.
-

2. Dynamic Analysis

- Running malware in a **safe, isolated environment** (sandbox or virtual machine).
 - Experts **observe its behavior** — like changes to files, registry, or network activity.
 - Purpose: See what the malware does in real-time.
-

Thank You

Lecture 7: Advanced Persistent Threats (APT)

What is APT?

APT stands for **Advanced Persistent Threat**.

It refers to **highly targeted and long-term cyberattacks** performed by **skilled and well-funded attackers**, such as:

- Nation-states
- Organized cybercriminal groups
- Advanced hacker teams

These attackers use **advanced tools and techniques** to secretly **infiltrate networks, steal sensitive data**, or **monitor systems** for a long period of time.

Main Features of APT:

- **Advanced:** Uses complex, custom-made malware and hacking methods.
- **Persistent:** Stays inside the target system for months or even years.
- **Targeted:** Focuses on specific organizations or individuals with valuable data.
- **Stealthy:** Designed to remain hidden while carrying out the attack.

Key Characteristics of APT

1. Advanced Techniques

APT attackers use sophisticated, custom-built tools and malware.

They avoid traditional antivirus detection and use **zero-day exploits, encryption, and multi-stage attacks**.

2. Persistence

An APT attack doesn't end quickly.

Attackers maintain **continuous access** for long periods, often staying undetected to collect intelligence or steal data slowly.

3. Targeted Attacks

Unlike regular cyberattacks that affect random victims, APTs target **specific organizations or sectors** like:

- Military and defense
- Government agencies
- Financial institutions
- Research and technology companies

Attackers do deep research to understand their target's system and weaknesses before attacking.

4. Stealth

APTs focus on **remaining invisible** to security tools and system administrators. They use **encryption**, **code obfuscation**, and **anti-analysis** methods to hide their activities.

5. Objectives

The main goals of APTs are:

- **Espionage (spying)** – stealing confidential data or government secrets
 - **Intellectual property theft** – stealing company designs or patents
 - **Sabotage** – disrupting critical operations or systems
 - **Long-term surveillance** – monitoring targets silently over time
-

6. Resourcefulness

APT groups have access to **large budgets, skilled hackers, and advanced technologies**. They plan and execute attacks like professional military operations, often funded by governments or powerful organizations.

7. Command and Control (C2)

After infection, APT malware connects to a **remote Command and Control server**. This allows attackers to:

- Send new commands
- Exfiltrate (send out) stolen data
- Update malware

- Control infected systems remotely
-

8. Zero-Day Exploits

APTs often use **zero-day vulnerabilities** — security holes unknown to software vendors. Since there is no patch yet, these attacks are **very effective and hard to prevent**.

Lifecycle of APT (APT Attack Lifecycle)

The **APT lifecycle** shows the stages of how an APT attack is planned, executed, and maintained over time.

Each stage helps attackers move closer to their goal while staying hidden.

1. Define Target

The attackers first **select their target** and define their goals.

They decide **who** they want to attack, **what** information they need, and **why**.

Example:

A hacker group may target a government database to steal classified defense documents.

2. Find and Organize Accomplices

The attackers then form a team with required expertise.

They may include:

- Programmers
 - Network specialists
 - Social engineers
- They also try to gain **insider access** by bribing or tricking employees.
-

3. Build or Acquire Tools

In this stage, attackers **create or buy** the tools needed for the attack.

These tools can include:

- Custom malware
 - Exploit kits
 - Keyloggers
 - Backdoors
- They may also buy access to existing compromised systems on the dark web.
-

4. Research Target

Attackers perform deep research on the target to find weaknesses. They collect information such as:

- Employee details
- Network structure
- Operating systems and software used
- Security policies and email formats

This step helps them plan a precise and effective attack.

5. Test for Detection

Before launching the real attack, attackers **test their malware** in controlled environments. They check whether:

- Security systems detect their tools
- Firewalls block communication
- Alarms or monitoring systems respond

If detected, they modify the malware until it can pass unnoticed.

6. Deployment

This is when the real attack begins. Attackers **deploy the malware** and begin infiltration. The infection might start through:

- Phishing emails
- Exploit kits
- Malicious USB drives
- Compromised websites

Once inside, they start exploring the system to find critical data.

7. Outbound Connection Initiated

Once a target is compromised, the infected system creates a **tunnel (connection)** back to the attacker's **C2 server**.

Through this connection, the attacker can:

- Send new instructions
 - Transfer stolen data
 - Download additional malware
-

8. Expand Access and Obtain Credentials

After gaining initial access, attackers move deeper into the network.

They:

- Steal or crack **login credentials**
- Use **privilege escalation** to become admin
- Install more malware
- Build a secret “ghost network” inside the target system

This step increases their control and reach.

9. Strengthen Foothold

Attackers secure their access by:

- Creating **backdoors**
- Infecting other connected devices
- Exploiting more vulnerabilities

They ensure that even if one entry point is removed, others still remain active.

10. Exfiltrate Data

After finding valuable data, attackers **collect and transfer it** to their remote servers.

Data may include:

- Financial information
 - Research and designs
 - Emails and credentials
- They often **compress and encrypt** the data to avoid detection during transfer.

11. Cover Tracks and Remain Undetected

Finally, attackers erase or hide any signs of the intrusion.
They may:

- Delete logs
- Remove temporary files
- Wipe malware traces
- Use fake timestamps

Their goal is to **stay invisible** and continue accessing the system for as long as possible.

Example of an APT Attack (Summary)

1. Attacker targets a specific organization.
2. Sends a phishing email containing malware.
3. Malware installs a backdoor.
4. The backdoor communicates with the C2 server.
5. Attacker moves laterally across systems.
6. Sensitive data is collected and exfiltrated.
7. Tracks are covered to remain undetected.

APT Summary Table

Stage	Action	Goal
1. Define Target	Choose victim and purpose	Strategic planning
2. Organize Team	Gather skilled hackers	Coordination
3. Build Tools	Create or buy malware	Attack preparation
4. Research Target	Collect info about network	Identify vulnerabilities
5. Test	Check if malware avoids detection	Stealth assurance
6. Deploy	Launch attack	Initial infiltration
7. Connect	Build remote link (C2)	Control infected system

Stage	Action	Goal
8. Expand	Gain more credentials	Deeper access
9. Strengthen	Secure presence	Long-term access
10. Exfiltrate	Steal data	Achieve goals
11. Hide	Cover tracks	Avoid discovery

Prevention and Defense Against APTs

To protect against APTs:

- Use **advanced firewalls and intrusion detection systems**.
 - Apply **regular software updates and patches**.
 - Monitor network traffic for **unusual activity**.
 - Train employees to identify **phishing emails**.
 - Use **multi-factor authentication (MFA)**.
 - Regularly back up sensitive data.
 - Implement **endpoint detection and response (EDR)** tools.
-

Thank You

Lecture 9: Footprinting, Reconnaissance and System Hacking

System Hacking

System hacking means **breaking into computer systems** to access, steal, or misuse their data. Attackers and malware look for **weaknesses** in systems and exploit them to gain unauthorized access.

Phases of System Hacking

System hacking usually follows these five steps:

1. **Reconnaissance / Footprinting** — Gather public information about the target.

2. **Scanning** — Probe the target to find open ports, services, and vulnerabilities.
 3. **Gaining access** — Exploit vulnerabilities to enter the system.
 4. **Maintaining access** — Create backdoors so the attacker can return.
 5. **Covering tracks** — Remove traces so the attack stays hidden.
-

1. Reconnaissance / Footprinting

Footprinting is the first phase. It means **collecting as much information as possible** about the target without directly accessing it.

This is mostly passive and uses public sources.

What attackers gather in footprinting:

- Company details and structure.
- Employee names and emails.
- Domain names and DNS records.
- Publicly exposed technologies and software versions.
- Social media and news about the organization.

Common footprinting methods (examples):

- **OSINT (Open Source Intelligence):** Searching websites, blogs, news, and social media.
 - **Whois lookups:** Finding domain registration details.
 - **DNS enumeration:** Finding subdomains and IPs.
 - **Search engines and archives:** Finding old or public documents.
-

Reconnaissance (active)

Reconnaissance here means **actively probing** the target to find technical details.

This is more risky because it can leave traces.

Active reconnaissance examples:

- **Port scanning** to find open services.
 - **Vulnerability scanning** to discover known security holes.
 - **Packet sniffing** to capture network traffic.
 - **Social engineering** to trick people into giving access.
-

Difference Between Footprinting and Reconnaissance

- **Method:** Footprinting is mostly **passive**; reconnaissance is **active**.
 - **Objective:** Footprinting maps and profiles the target; reconnaissance finds exploitable weaknesses.
 - **Risk:** Footprinting is low risk (legal in many cases); reconnaissance may trigger defenses and legal issues.
 - **Legality:** Footprinting can be legal; reconnaissance that interacts with systems can be illegal without permission.
-

2. Scanning

Scanning means using tools to probe the target system. The goal is to find live hosts, open ports, running services, and known vulnerabilities.

Three types of scanning:

- **Port scanning:** Find open ports and services.
 - **Network mapping:** Discover network devices and topology.
 - **Vulnerability scanning:** Identify software versions and known vulnerabilities using automated scanners.
-

Port Scanning

Port scanning sends requests to many ports and records which ports respond. This reveals which services a host runs.

Port scanning protocols & techniques (common examples):

- **TCP scans:** Full connect (TCP Connect), SYN (half-open), FIN/NULL/XMAS (stealth).
- **UDP scans:** Check for UDP services.
- **ICMP / Ping scans:** Check if hosts are alive.
- **IPv6 scanning:** For IPv6 addresses and services.
- **Stealth scans:** Try to avoid detection by IDS/IPS.

(Examples in slides: Ping scan, SYN scan, TCP Connect scan, UDP scan, Stealth scan.)

Network Mapping

Network mapping builds a visual map of the target network. It shows routers, firewalls, servers, and how devices are connected.

This map helps an attacker or tester plan further steps and find valuable systems. Network maps also help defenders spot weak points.

3. Gaining Access (Exploitation)

Gaining access means using an exploit, weak credentials, or other attacks to enter the system.

Common actions:

- Use exploits for known vulnerabilities.
- Bypass authentication using stolen credentials or brute force.
- Exploit weak services found during scanning.
- Use social engineering to get a user to run malware.

Once access is gained, attackers typically try to escalate privileges to get administrator or root rights.

4. Maintaining Access

After entry, attackers install tools to **keep access** over time. Methods include:

- Installing **backdoors** or remote shells.
 - Creating new user accounts with admin rights.
 - Modifying startup scripts or tasks so malware runs at boot.
 - Planting persistence tools that survive reboots or simple cleaning.
-

5. Covering Tracks

Attackers try to **erase evidence** so their presence is not found. Typical techniques:

- Clearing or tampering with system logs.
 - Deleting temporary files and tools.
 - Changing timestamps or log entries.
 - Using rootkits or hidden processes to avoid detection.
-

Example System Hacking (Linux)

A short example flow when attacking a Linux web server (example target: `https://test.daffodilvarsity.edu.bd`):

1. **Reconnaissance:** Ping the domain to find the server IP.
2. **Scanning & Enumeration:** Use tools (e.g., Zenmap) to find open ports and services on the server.
3. **Vulnerability Analysis:** Search vulnerability databases for known issues in the server software version.
4. **Gaining Access:** Use an exploit (for example, a known Metasploit module) to get a shell on the server.
5. **Maintaining Access & Privilege Escalation:** Install backdoors, create admin accounts, escalate to root.
6. **Covering Tracks & Data Collection:** Remove logs, collect sensitive data, and maintain persistence.

(Example exploit shown in slides: `vsftpd_234_backdoor` Metasploit module on Rapid7.)

Important Notes (Legal & Ethical)

- **Unauthorized scanning or hacking is illegal** in most places.
- Only perform active tests on systems you **own** or have **explicit permission** to test (e.g., penetration testing with contract).
- Footprinting and OSINT can be ethical if used for defensive research and with care.

Thank You

Lecture 9 — Condensed Study Notes (Same Structure)

System Hacking — Breaking into systems to steal or misuse data.

Phases (5):

- Reconnaissance / Footprinting — passive data collection from public sources.
- Scanning — find open ports, services, and vulnerabilities.
- Gaining access — exploit weaknesses to enter.
- Maintaining access — backdoors and persistence.

- Covering tracks — delete logs and hide evidence.

Footprinting (passive):

- OSINT, Whois, DNS enumeration, social media, public docs.
- Low risk; builds target profile.

Reconnaissance (active):

- Port scans, vulnerability scans, packet sniffing, social engineering.
- Higher risk; may trigger alerts.

Scanning types:

- Port scanning (TCP/UDP), network mapping, vulnerability scanning.
- Techniques: TCP Connect, SYN, FIN/NULL/XMAS (stealth), UDP, Ping.

Gaining access:

- Use exploits, stolen credentials, or social engineering.
- Aim to escalate privileges (user → admin).

Maintaining access:

- Backdoors, startup persistence, hidden accounts.

Covering tracks:

- Clear logs, remove tools, modify timestamps, use rootkits.

Example flow (Linux web server):

- Ping → Scan (Zenmap) → Find exploit → Use Metasploit → Maintain access → Exfiltrate data → Cover tracks.

Quick tips for defenders:

- Monitor logs and network activity.
- Patch software and reduce exposed services.
- Use strong passwords and MFA.
- Limit privileged accounts and review changes.
- Train users against social engineering.

What is Enumeration?

Enumeration is the process of **extracting detailed information** from a target system after scanning and reconnaissance.

It is a **crucial step in ethical hacking or penetration testing** because it provides deeper access to system data.

Attackers use er:

- **Username and passwords**
- **Network shares**
- **System resources and running services**
- **Groups and policies**
- **Applications and banners**

Enumeration transforms gathered data into **useful attack information** that helps exploit the target later.

Enumeration Explained

n attacker connects directly to the target to gather data using active queries.

It is **more intrusive than footprinting**, and therefore **easier to detect** by security systems.

Common Targets of Enumeration

- **Operating sysetwork resources and shares**
- **User account details**
- **Default or weak passwords**
- **Service settings and banners**

Techniques Used

- Querying **network services** (FTP, SMTP, SNMP, DNS, etc.)
- Using **scripts or tools** to extract system information
- Exploiting **misconfigured services** or permissions

Purpose of Enumeration

The main purpose is to **identify valides, and weaknesses** that can be used to gain higher privileges.

Goals of Enumeration

1. **Gather network information** – names, addresses, shares.
 2. **Find user accounts and groups.**
 3. **Collect service configurations and versions.**
 4. **Discover passwords or authentication mechanisms.**
 5. **Detect weak or misconfigured permissions.**
-

Types of Enumeration

1. NetBIOS Enumeration

NetBIOS (Network Basic) is a communication service used in older Windows networks. It helps computers share files, printers, and resources.

Attackers use **NetBIOS enumeration** to:

- Obtain **computer names and IP addresses**
- Find **logged-in users**
- Access **shared folders and printers**
- Identify **network structure**

Tools used:

- `nbtstat` (built into Windows)
- Hyena
- NetBIOS Enumerator

Command Example (Windows):

```
nbtstat -A <Target_IP>
```

It displays the **NetBIOS name table** and active sessions.

2. SNMP Enumeration

SNMP (Simple Network Management Protocol) is used to monitor and manage networks and switches.

If SNMP is not properly secured, attackers can extract valuable information.

SNMP Enumeration reveals:

- System names and descriptions
- Installed software
- Network interfaces
- Routing tables
- Device configuration details

Common tools:

- snmpwalk
 - snmpcheck
 - SolarWinds SNMP Scanner
-

3. LDAP Enumeration

LDAP (Lightweight Directory Access Protocol) is used in Windows Active Directory to manage user a

Through LDAP enumeration, attackers can discover:

- **Domain names**
- **Usernames and email addresses**
- **Group membership**
- **Password policies**

Tools used:

- ldapsearch (Linux)
 - Softerra LDAP Browser
 - ADEplorer
-

4. NTP Enumeration

NTP (Network Time Protocol) keeps systems' clocks synchronized.
An attacker can use NTP to:

- Learn **server names aonnected clients**
- Extract **system uptime**
- Discover network topology

Tool: ntpq or ntpdc command

5. SMTP Enumeration

SMTP (Simple Mail Transfer Protocol) is used to send and receive emails. SMTP servers sometimes respond with **user verification command

SMTP Enumeration can reveal:

- Valid **email usernames**
- Server software and version
- Internal mail routes

Common commands:

- VRFY (Verify user)
- EXPN (Expand mailing list)
- RCPT TO (Confirm recipient)

Tools:

- Telnet
 - smtp-user-enum
 - Metasploit auxiliary scanner
-

6. DNS Enumeration

DNS (Domain Name System) maps domain names to IP addresses. Through DNS enumeration, attackers collect:

- **Hostnames and IP addresses**
- **Mail servers Name servers (NS records)**
- **Zone transfer data**

Common tools:

- nslookup
- dig
- dnsenum
- Fierce

Command Example:

```
nslookup -type=any example.com
```

7. Windows Enumeration

Windows systems can reveal large amounts of data if not configured securely.

Attackers may discover:

- **Username and groups**
- **Shared resources**
- **System policies** gs**

Tools:

- enum
- net view, net user commands
- Hyena, DumpSec

8. Linux / UNIX Enumeration

In Linux or UNIX systems, attackers can collect information such as:

- User accounts (/etc/passwd)
- Group information (/etc/group)
- Running services (netstat, ps)
- System kerne*Commands:**

```
cat /etc/passwd
uname -a
netstat -tuln
ps aux
```

Enumeration Tools Summary

Enumeration Type	Tools
NetBIOS	nbtstat, Hyena
SNMP	snmpwalk, snmpcheck
LDAP	ldapsearch, ADExplorer
NTP	ntpq, ntpdc
SMTP	Telnet, smtp-useokup, dig, dnsenum
Windows	net view, DumpSec
Linux	cat, uname, netstat

Countermeasures Against Enumeration

To defend against enumeration attacks:

- Disable unnecessary **services and ports**.
 - Use **firewalls** to restrict public access.
 - Apply **strong passwords** and **multi-factor authentication**.
 - Disable **anonymous accounts**.
 - Limit information in system banners.
 - Regularly **patch and update** software.
 - Enable **intrusion detection systems (IDS)**.
-

Summary

- Enumeration is the **active collection of detailed information** about a target.
 - It occurs after scanning and before exploitation.
 - Common targets include users, groups, shares, and network configurations.
 - It uses many network services such as ****NetBIOS, SNMP**, - Always secure and monitor these services to prevent data leakage.
-

Thank You